



POONAWALLA
FINCORP

Cyber Incident Response Procedure



Standard Operating Procedure: Cyber Incident Response

Standard Operating Procedure for Cyber Incident Response

Version	4.0
Effective Date	13/10/2025
Compiled by	Saurabh Kumar
Reviewed by	Ratnesh Singh
Approved by	Chief Information Security Officer (CISO)

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.0	23-01-2023	First Copy	Hiten Kumar	Nikhil Bhujade	CTO
2.0	16-01-2024	Escalation Matrix, Threat Vectors, Data Breach Response, RACI Matrix	Hiten Kumar	Sumit Rangari	CISO
3.0	03-07-2024	Updated Escalation Matrix	Ratnesh Singh	CISO	CRO
3.1	19-05-2025	Added additional regulators in the list of regulators	Saurabh Kumar	Ratnesh Singh	CISO
4.0	13-10-2025	1. Added Cyber crisis definition, 2. Updated RACI matrix 3. Updated in Cyber Crisis Management Team	Saurabh Kumar	Ratnesh Singh	CISO



Standard Operating Procedure: Cyber Incident Response

Contents

1. PURPOSE:	4
2. SCOPE:	4
3. DEFINITION:	4
4. CYBER CRISIS MANAGEMENT TEAM	5
5. WHAT IS CYBER ATTACK	5
6. RESPONSIBILITY	6
7. CYBER RESPONSE MANAGEMENT DEFINITION:	7
8. CYBER RESPONSE MANAGEMENT PROCEDURE:	8
9. FORENSICS AND ROOT CAUSE ANALYSIS AND PREVENTIVE MEASURES:	10
10. POST ATTACKS:	11
11. EXAMPLE OF ACTIVITIES IN COMMON ATTACK SCENARIOS:	12
12. INCIDENT RESPONSE UNDER DATA BREACH CONDITION	14
13. RBI & CERT-In TEMPLATE FOR REPORTING CYBER INCIDENTS:	15
14. ESCALATION MATRIX	15
15. RACI MATRIX:	15
16. REVIEW	16



Standard Operating Procedure: Cyber Incident Response

1. PURPOSE:

The purpose of this document is to provide guidance for responding in case of cyber-attacks on PFL Infra. It includes steps which need to be followed during below phrases:

1. Detect
 2. Response
 3. Containment
 4. Recovery
 5. Communication
- For information security incidents, Information Security Incident Response SOP shall be referred.
 - To manage business interruptions in order to provide the continuity of services at a minimum acceptable level and to safeguard the financial and competitive position of PFL.
 - To enable PFL to recover or maintain its activities in the event of cyber-attacks affecting normal business operations such as ransomware attacks, code attacks, phishing attacks etc.
 - To define a framework for the identification, management, and mitigation of cyber-attacks within the organization.

2. SCOPE:

- This procedure document includes guidance, initial actions, and procedures to respond cyber-attacks on PFL Infra.
- This document addresses only incidents that are computer security related, not those caused by natural disasters or power failures.
- The document is intended to provide framework and processes by which consistent approaches can be developed and resource allocation can be made for a given scenario to facilitate the detection, identification, containment, eradication, and recovery from Cyber-attacks.

3. DEFINITION:

PFL	:	Poonawalla Fincorp Limited
CRO	:	Chief Risk Officer
CISO	:	Chief Information Security Officer
CTO	:	Chief Technology Officer
CCO	:	Chief Compliance Officer
HR	:	Human Resource
PR	:	Public Relation
IT	:	Information Technology
SOC	:	Security Operation Center



Standard Operating Procedure: Cyber Incident Response

BCP	:	Business Continuity Plan
DR	:	Disaster Recovery
IS	:	Information Security
CCMT	:	Cyber Crisis Management Team
Cyber-attack	:	A cyber-attack is any offensive maneuver that targets Computer information system, computer network, Infrastructure or personal computer devices
Data Breach	:	The unauthorized exposure, disclosure or loss of personal and company confidential information.

4. CYBER CRISIS MANAGEMENT TEAM

CCMT shall act as a central point for monitoring to provide oversight for Cyber Crisis management and governance. The CCMT will have following members:

- Head of Risk/CRO – Chair Person
- CTO
- Information Security Head
- Operations Head
- Legal and Compliance Head
- HR Head
- Corporate Communication (PR) Head
- Concerned Business Heads

5. WHAT IS CYBER ATTACK

Cyber-attack is a process to gain unauthorized access to a computer, computing system or computer network which hampers the confidentiality, integrity, and availability of the PFL systems network.

A cyber-attack may involve, but is not limited to, any or all of the following:

- Targeted scanning/probing of critical networks/system.
- Compromise of critical systems.
- Data breach/data leak
- Attack or incident affecting digital payment systems.
- Unauthorized access to social media.
- Website Defacement:
 - a) PFL corporate website is completely taken down
 - b) Unauthorized changes made the appearance of an entire site
- DOS and DDOS Attacks:



Standard Operating Procedure: Cyber Incident Response

- a) Non-availability of services due to overwhelming malicious network traffic on internet links.
 - b) System crashes due to overwhelming utilization of computing resources
- DNS Cache Poisoning
 - a) Redirection of legitimate web/mail traffic to suspicious websites/mail servers
- Application-Level Attacks
 - a) Unauthorized changes to data, elevation to privilege account, suspicious user activities, presence of malicious links/content due to exploitation of application vulnerabilities
- Advanced Malwares and Persistence Threats on Servers
 - a) Unexpected potentially legitimate traffic to suspicious internet IPs
 - b) Substantial scanning activity originating from a client or a server
 - c) Unexplained poor system performance.
 - d) Presence of suspicious process/files on system
 - e) Unexpected Surge in traffic on ports/services used by malware
 - f) Connections to suspicious remote systems.
- Ransomware Attacks on Server
 - a) A message for asking ransom is displayed along with a key
 - b) Identification of critical server files are being encrypted due to unknown reasons.
- Phishing Email/Business Email Fraud/Spam
 - a) Unexpected emails from known or unknown individuals
 - b) Emails that contain links and/or attachments, Phishing emails often prompt extreme feelings to push the user in the direction the malicious actor wants
- Identity Fraud/Password Fraud
 - a) Unexpected emails from known or unknown individuals asking for PII data or password change/expiry alert
 - b) You're notified that your information was exposed in a data breach

Potential cyber-attacks shall be escalated as confirmed cyber crisis based on following:

- Cyber-attacks on critical applications, servers, and network devices (Routers, Switches, Firewalls, Access Points).
- Cyber-attack involving significant breakdown of supplies for services essential to carry out the mission critical activities across the organization.
- Non-availability of services due to cyber-attacks.
- A targeted cyber-attack damaging brand image, public and customer confidence.

6. RESPONSIBILITY

Incident Response Phases	Responsibility
Detection of security and identification of potential cyber attacks	SIEM tool – Managed services team (SOC Team) PSD tool – Information security team (SOC Team) Reported by End user
Declaration of cyber attacks	CTO, CISO and CRO will decide whether the incident qualifies as a crisis or not and accordingly they will declare the same to necessary



Standard Operating Procedure: Cyber Incident Response

	stakeholders. Post crisis declaration, Internal and external communication will be done as per defined process.
Respond, Containment and Recovery	IT Infra, Network and Applications team shall be responsible for respond, containment and recovery in consultation with CTO, CISO and Information Security.
Communication	For internal employee – HR team/Internal Communication team For external communication – PR team For regulatory – Compliance

7. CYBER RESPONSE MANAGEMENT DEFINITION:

Detection	Response	Containment	Recovery	Communication
-----------	----------	-------------	----------	---------------

- **Detection:** Threat detection is the practice of analyzing the entirety of a security ecosystem to identify any malicious activity that could compromise the network.
- **Response:** Developing a containment strategy, identifying the hosts and systems under attack, mitigating the effects, and having a plan for recovery.
- **Containment:** Containment is a methodology whereby access to information, files, systems, or networks is controlled via access points.
- **Recovery:** Cyber Recovery is a data protection solution intended to address the risk of data loss due to ransomware attacks and other critical cyber-attacks.
- **Communication:** A cybersecurity communications strategy will include data breach response preparations, staff, and executive training for handling the situation, scenario testing and planning, and a crisis communication plan to manage the issue and get back to business as usual.

Common Threat Vectors:

The table below contains common threat vectors from the Computer Security Incident Handling guide for identifying the initial vector.

Type	Description
Email	Email viruses consist of malicious code distributed via email to infect one or more devices.
Web	An attacker to execute malicious scripts in another user's browser. However, instead of attacking the victim directly, the attacker exploits a vulnerability on internet facing PFL's website through malicious script or some other tactics.
Improper usage	An incident resulting from violation of an organization's acceptable usage policies by an authorized user, excluding other categories such as external/removable media, email, web, attrition, and loss or theft of equipment, is considered as improper usage in security operations



Standard Operating Procedure: Cyber Incident Response

8. CYBER RESPONSE MANAGEMENT PROCEDURE:

➤ **Detection of security and identification potential cyber attacks**

- SOC Teams (managed services) will analyze the identified security events monitored through SIEM tool and reported through various sources to detect security incidents such as open web, threat intel, IRC (Internet Relay Chat), IOCs and Dark/deep web.
- SOC Teams (Information security) will analyze the identified security events monitored through PSD tool.
- SOC Teams will perform initial assessment of detected security incidents to identify potential cyber-attack and classify the incidents as High (P1), Medium (P2) and Low (P3).
- Any incident that disrupts critical operations, compromises sensitive data, or poses a serious threat to an organization's digital infrastructure may be considered as Cyber Crisis, and same will be presented to CTO/ CRO/ CISO for crisis declaration. Refer Annexure.
- SOC Teams will immediately inform cyber-attack to the CISO.
- If an attack such as phishing, vishing, spamming etc. was performed or attempted on end user system, then they need to immediately inform the Information Security team by raising the incident ticket in cyber information security incident categories on PSD tool.
- Any such incident reported by end-users will be addressed, reclassified as defined process. Refer annex for details.

➤ **Declaration of cyber attacks**

- Information Security team along with CTO, CRO, CISO, IT application team, IT infrastructure team and other relevant stakeholders shall evaluate potential cyber-attacks.
- Assess the situation to identify impact and affected systems to confirm cyber-attack.
- CTO, CRO and CISO will decide whether cyber-attacks need to be declared after urgent discussion with necessary stakeholders.

➤ **Respond, Containment and Recovery**

- Once cyber-attacks are declared, concerned team will be advised immediately as per below scope areas (All the cyber-attack incident shall be routed through Information Security team to concerned department):
 - ✓ Applications - Application team shall investigate the security incident in coordination with Information Security team, network, and IT Infrastructure team.



Standard Operating Procedure: Cyber Incident Response

- ✓ Servers – IT Infrastructure team shall investigate the security incident in coordination with the Information Security team and network team.
- ✓ Network Devices - Network team shall investigate the security incident in coordination with Information Security team.
- ✓ End User System - End user support team in coordination with Information Security team.
- Information security team along with CTO, CISO, IT application team, IT infrastructure team will analyze the cyber-attack to identify possible cause and determine possible containment, eradication, and recovery actions.
- Thereafter, the concern team shall perform determined actions to first containment of the attack and then to eradication and recover from attack.
- Possible investigation and analysis actions:
 - ✓ The respective teams (Application, Server, Network and End user) involved with attack handling should investigate and diagnose what has gone wrong.
 - ✓ Information security team will examine log files and other data to determine & collect related intelligence details such as how and when the attack occurred, source of attack, volume, attacker details, no. of users or customer impacted etc., depending on the type of attacks.
 - ✓ Engage with respective team to understand other specifics about the attacks.
 - ✓ Check all systems log to determine if other malicious activities are involved with the current attacks.
 - ✓ Information security team will engage with forensics services partner for investigation as needed.
 - ✓ Adequate data to ensure that event analysis can be completed without any hindrance should be captured as part of the logs.
 - ✓ All investigations and diagnosis are fully documented and maintain the complete historical record of attacks.

➤ **Communication:**

Communication among the teams shall be done based on confirmed cyber-attack to help limit confusion, increase responsiveness and transparency. Guidelines for composing and creating communication plans:

- Collect information on the situation, its background, the possible consequences, how it is being handled.
- Describe what happened and what is happening. Give full details which shall be helpful in assessing the situation.



Standard Operating Procedure: Cyber Incident Response

- Select relevant, reliable communication channels (external interfaces) and internal interfaces (Notice boards, Public Address system (PA), Television displays etc.).
- Execute the plan: Inform key interested parties, deliver information to internal audiences and media, employees by choosing appropriate mediums for dissemination.
- Respond to enquiries and update the information when necessary.
- Maintain a calm and composed outlook toward the cyber-attack to avoid creating panic.

What to communicate	Responsibility
Advise Cyber Crisis Management Team (CCMT) once cyber crisis is declared	CTO/CRO/CISO/Information Security Team
Periodic updates on Cyber Crisis to CCMT	Information security team
To avail forensics Services Partner for investigation	Information security team/ CRO/CISO
Filling up RBI and CERT-In incident reporting form and its review	Information security team/CISO
Communicate the crisis to senior leadership	CTO/ CRO
Reporting of cyber crisis to CERT-In RBI / Regulatory Body	Compliance Team/CTO/CRO/CISO
Consult with the CCMT members on understanding the crisis and preparing an appropriate response for customers, external parties, media and stakeholders– if required	Head Corporate Communication (PR)
Update to employees on the current situation and appropriate steps to be taken by them	HR Team/Internal Communication team
Law Enforcement Agencies	Legal & Compliance
Seek external legal and/or professional advice if required	Legal & Compliance

9. FORENSICS AND ROOT CAUSE ANALYSIS AND PREVENTIVE MEASURES:

- Conduct forensics and root cause analysis. More details, refer Digital Forensic SOP.
- Engage with forensics services partner for investigation as needed.
- Based on root-cause analysis, identify preventive measures, and implement them to prevent reoccurrence of attack.
- Consider following guidelines for preservation of evidence.
- Every evidence will be preserved on an as is basis, to ensure its integrity.
- Any actions that may suggest tampering of evidence will be avoided.



Standard Operating Procedure: Cyber Incident Response

- Every action (including symptoms of the problem) pertaining to the evidence will be thoroughly and unambiguously documented. This ensures that the scope for challenging the data, by resorting to multiple interpretations, is reduced.
- Access to the evidence should be strictly controlled. This is important in order to substantiate the claim that the logs are tamper-proof.
- Before shutting down the system containing the evidence, all data with respect to messages on the screen, memory contents, state of network connections, state of running processes will be noted.
- The following mistakes are to be avoided when handling evidence:
 - ✓ Altering time and date stamps on evidence systems before recording them.
 - ✓ Terminating rogue processes.
 - ✓ Patching the system before investigators respond.
 - ✓ Using untrusted commands and binaries.
 - ✓ Writing over potential evidence by installing software on the hard drive.
- Below are the list of Investigation Questions, these may be answerable with the data available, and questions may change as our investigation progresses.
 - ✓ What were the initial indicators of the incident, and how were they identified?
 - ✓ What systems or assets were compromised? What level of privilege?
 - ✓ Does the attacker have persistence on the network or device?
 - ✓ Is lateral movement suspected or known? Where has the actor laterally moved to and how?
 - ✓ How is the attacker maintaining command & control?
 - ✓ Has the data been exfiltrated? what data might have been accessed or exfiltrated?

10. POST ATTACKS:

The following things follow recovery from attacks situation and should be taken seriously:

- Declaration of attacks closure and advising authorities.
- Information security team and respective teams (application, server, network, and End point) to update and distribute final attacks report to relevant stakeholders.
- Information security and respective team (application, server, network, and End point) will document the learning from the entire episode and strength security posture of organization.
- CTO, CRO, CISO and respective stakeholder shall decide classification of the incident after having discussion whether incident is High (P1), medium (P2) and low (P3) - as per SOC process document.
- Based on the management decision on the criticality of the incident, the communication shall be forwarded to other stakeholders/departments (refer to communication section).



Standard Operating Procedure: Cyber Incident Response

- The information security team will document lessons learned from the cyber incident and will conduct tests in drill whenever possible.

11. EXAMPLE OF ACTIVITIES IN COMMON ATTACK SCENARIOS:

Following are examples of common attack scenarios which may not necessarily lead to cyber-attack by itself.

1.Website defacement	
Symptoms /Alerts	Possible Actions
1. A website is completely taken down and replaced by something new. 2. Unauthorized changes made the appearance of an entire site.	- Disconnect the Web Server hosting defaced /compromised website. - Examine the compromised system /website for specific unauthorized changes. - Restore the website content, Shift, and run website from a different trusted system by making appropriate DNS changes at the new system - Collect relevant logs of server and application.
2. DOS and DDoS Attack	
Symptoms /Alerts	Possible Actions
1. Non-availability of services due to overwhelming malicious network traffic on internet links. 2. System crashes due to overwhelming utilization of computing resources	- Apply appropriate rate limiting strategies at the local perimeter and mitigation at ISP. - Identify the type of attack such as flooding of particular types of packets/requests (TCP SYN, ICMP etc.) by examining logs of Router/IPS/IDS/ Firewall. - Check Router configuration and implement Egress and Ingress filtering to block spoofed packets. - Use appropriate DoS and DDoS prevention tools / services. - Disable the non-essential ports/services. - If problem persists shift web/mail services hosting to alternate Internet Protocol (IP) addresses
3.DNS Cache Poisoning Attacks	
Symptoms /Alerts	Possible Actions
1. Redirection of legitimate web/mail traffic to suspicious websites/mail servers	- Purge cache - Restart DNS server - Replace DNS records with content from trusted backup - Examine DNS forwarding traffic to identify rogue DNS server and block. - Restrict rights of configuration changes to Administrator only. - At client side, delete any additional entries in HOSTS file. - Use appropriate DNS attack monitoring / prevention tools / services.
4.Application-Level attacks	
Symptoms /Alerts	Possible Actions
1. Unauthorized changes to data, elevation to privilege account, suspicious user	- Perform analysis of IDS/IPS/WAF/SIEM/Servers/Application logs to identify cause. - Disable suspected user accounts - Reduce the interactive features and run with minimum essential features - Restore data from trusted backup



Standard Operating Procedure: Cyber Incident Response

activities, presence of malicious links/content due to exploitation of application vulnerabilities	- Identify attack sources from application logs and block - Enforce Input validation - Apply latest patches/updates to mitigate application vulnerabilities - Use appropriate web application attack monitoring / prevention tools / services such as web application firewall, web application security assessment services etc.
--	--

5. Advanced malwares and persistent threats on servers

Symptoms /Alerts	Possible Actions
- Unexpected potentially legitimate traffic to suspicious internet IPs - Substantial scanning activity originating from a client or a server - Unexplained poor system performance. - Presence of suspicious process/files on system - Unexpected Surge in traffic on ports/services used by malware - Connections to suspicious remote systems.	- Search if any machine infected with APT. - Isolate possible infected machine and install new system by restoring from last known clean backup - Take a copy of all logs at the perimeter level (Firewall, IPS) and traffic trends - Scan all the open ports which are not required and close them. - Apply latest security patch/update - Use appropriate Advanced malware and Anti APT monitoring / prevention tools / services, Threat intelligence services.

6.Ransomware Attack on servers

Symptoms /Alerts	Possible Actions
- A message for asking ransom is displayed along with a key - Identification of critical server files are being encrypted due to unknown reason.	- Isolate system from network - Validate that the available backup is error free - Install new system by restoring from last known clean backup - Update the anti-virus and anti-malware and scan the system/ network before resuming the operations - Keep file extension visible setting on. - Apply latest security patch/update - Use appropriate Advanced malware and Anti APT monitoring / prevention tools / services, Threat intelligence services.

7.Phishing email /Business email fraud/Spam

Symptoms /Alerts	Possible Actions
- Unexpected emails from known or unknown individuals - Emails that contain links and/or attachments, Phishing emails often prompt extreme feelings to push the user in the direction the malicious actor wants	- Quarantine the malicious email from all accounts on the system - Under SIEM, check to see if there are any custom threat intelligence rules to add. - Contain. Shut down the email account so that no users can access it. - Examine what is in your email that got compromised



Standard Operating Procedure: Cyber Incident Response

8.Identity fraud/password fraud	
Symptoms /Alerts	Possible Actions
1. Unexpected emails from known or unknown individuals asking for PII data or password change/expiry alert 2. You're notified that your information was exposed in a data breach	• User will inform to Information Security team • Information Security team shall analyze the email header • Based on analysis, Information Security team shall suggest blockage of IOCs, Ips and domains etc.

12. INCIDENT RESPONSE UNDER DATA BREACH CONDITION

Defining a Data Breach

A Data Breach is an Information Security Incident (concerning technology assets, online platforms, paper records and/or oral or visual information sharing) in which:

- Sensitive, protected, or confidential data that is obtained without authorization, then destroyed, lost, altered, disclosed, or accessed by an unauthorized individual or group.
- Specific legal definitions, federal or international breach laws, have been met or are believed to have been met.

Escalating and Responding to a Data Breach

PFL defines the conditions under which a data breach must be reported to external entities, such as local and federal or government authorities (RBI, SEBI, CERT-IN).

Data breach conditions are to be escalated to the Cyber Incident Management Team (CCMT), which is tasked with overseeing the response and ensuring compliance with legal and regulatory requirements. The CCMT is responsible for notifying PFL's Business Continuity Teams should the breach result in a business-disrupting event.

Operating procedures used to support response actions under non-breach conditions may be relied upon to support the actions prescribed by the CCMT.

The CCMT shall determine the degree, method(s), and timing for reporting a data breach condition to external and impacted parties. Such disclosures may only be done by Individuals authorized by the CCMT and must follow legal requirements or regulations.

Standard Operating Procedure: Cyber Incident Response**13. REPORTING CYBER INCIDENTS TO REGULATORS & AUTHORITIES:**

All cyber incidents shall be reported to applicable regulators / authorities such as RBI, Cert-In, IRDAI, UIDAI (if applicable) within prescribed time limits by the respective regulators (e.g. within six hours of detection of incidents) and other authorities on case-to-case basis if applicable like SEBI, Indian cybercrime co-ordination center, IRDAI etc.



Cyber Incident
Reporting Template



CERT-In Template
for Reporting Cyber

For detailed information, please refer to the annexure/s.

14. ESCALATION MATRIX

- ✓ Point of contact for Information / Cyber security related incidents.

Escalation Level	Name	Infosec	Contact No	Designation
Level 1	Infosec	infosec@poonawallafincorp.com	-	Infosec Support
Level 2	Ratnesh Singh/ Sumit Rangari	ratnesh.singh@poonawallafincorp.com / sumit.rangari@poonawallafincorp.com	7032717376/ 9860257758	AVP
Level 3	Nikhil Bhujade	nikhil.bhujade@poonawallafincorp.com	8956594991	CISO

- ✓ Point of contact for IT Infrastructure related incidents.

Escalation Level	Name	IT Infra	Contact No	Designation
Cloud-Level 1	Cloud Team	dc.wintel@poonawallafincorp.com	NA	NA
Cloud-Level 2	Dheeraj Kale	dheeraj.kale@poonawallafincorp.com	9920600341	GM – IT Infra
Network-Level 1	Network Team	dc.network@poonawallafincorp.com	NA	NA
Network-Level 2	Nilesh Waykar	nilesh.waykar@poonawallafincorp.com	9881335584	Network Lead
Cloud / Network Level 3	Chandresh Yadav	chandresh.yadav@poonawallafincorp.com	9920044647	VP - Infra Head
Level 4	Salil Hajarnis	salil.hajarnis@poonawallafincorp.com	9823216761	CTO

15. RACI MATRIX:

#	Action Item	Responsible	Accountable	Consulted	Informed
1	Cyber Incident detection	End Users/ MSSP SOC Team	Information Security Team	CISO	CRO



Standard Operating Procedure: Cyber Incident Response

2	Cyber Incident Identification and classification	PFL SOC Team	Information Security Team	CISO	CRO
3	Notification to Stakeholders (Internal)	PFL SOC Team	Information Security Team,	CISO	CRO, CTO
4	Response, Containment & Recovery	SOC Team, Respective Team (IT, INFRA, Application)	Information Security Team	CISO, IT Governance	CRO, CTO
5	Analysis of Incident	PFL SOC Team & Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance,	CISO, CTO	CCMT
6	Root cause Analysis of the Incident	Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CCMT
7	Impact Assessment of the Incident	Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CCMT
8	Incident/ ticket Closure	MSSP SOC Team, Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CRO
9	Declaration of cyber attack	CISO	IT Governance	CRO	CCMT
10	Periodic updates on Cyber attack	PFL SOC Team	CISO	CTO, CRO	CCMT
11	Coordinate with forensics services partner	PFL SOC Team	CISO	CRO	CCMT
12	Communication - update to employees	HR Team	Head of HR	CCMT	CCMT
13	Communication - update to external parties (if required)	PR Team	Head of HR	CRO, CISO, CTO	CCMT
14	Seek external legal and/or professional advice (if required)	Legal, Compliance	Compliance	CRO, CISO, CTO	CCMT
15	Filling up RBI, CERT-In or other incident reporting form	PFL SOC Team / Information security team	CISO	CRO	CCMT
16	Reporting to External / Regulators	Regulators - Compliance / Information Security Team Media - Head Corporate Communication (PR) /	Information Security Team, IT Governance	CISO, CTO	CCMT

16. REVIEW

This document shall be reviewed at least once annually or whenever any changes occur in the process or regulatory requirements.



Standard Operating Procedure: Cyber Incident Response

Annexure

A. RBI template for Reporting Cyber incident

Security Incident Reporting (SIR) to RBI (within 24 hours):

Subsequent update(s) RBI (updates to be provided if the earlier reporting was incomplete i.e. investigation underway or new information pertaining to the incident has been discovered or as per request of RBI):

Basic Information	
1) Particulars of Reporting:	
Name of the NBFC -	
Date and Time of Reporting to RBI, CERT-IN, other agencies (please mention separately time of reporting to each) -	
Name of Person Reporting -	
Designation/Department -	
Contact details (e.g. official email-id, telephone no, mobile no)	
2) 2. Details of Incident:	
Date and time of incident detection	
Type of incidents and systems affected 1) Outage of Critical IT system(s) (e.g. CBS, Treasury Systems, Trade finance systems, Internet banking systems, ATMs, payment systems such as SWIFT, RTGS, NEFT, NACH, IMPS, etc.) 2) Cyber Security Incident e.g. DDOS, Ransom ware/crypto ware, data breach, data destruction, web defacement, etc.)? [Please complete Annex] 3) Theft or Loss of Information (e.g. sensitive customer or business information stolen or missing or destroyed or corrupted)? 4) Outage of Infrastructure (e.g. which premises-DC/Central Processing Units, branch, etc. power/utilities supply, telecommunications supply,)? 5) Financial (e.g. liquidity, bank run)? 6) Unavailability of Staff (e.g. number and percentage on loss of staff/absence of staff from work 7) Others (e.g. outsourced service providers, business partners, breach of IT Act/any other law and RBI/SEBI regulations. Etc.)?	
What actions or responses have been taken by the NBFC at the time of first reporting/till the time of subsequent reporting?	
3) Impact Assessment (examples are given but not exhaustive):	
Business impact including availability of services - Internet banking, Cash Management, Trade Finance, Branches, ATMs, Clearing and Settlement activities, etc.	
Impact on stakeholders- affected retail/corporate customers, affected participants including operator(s), settlement institution(s), business partners, and service providers, etc.	
Financial and market impact – Trading activities, transaction volumes and values, monetary losses, liquidity impact, withdrawal of funds etc.	
Regulatory and Legal impact	
4) Chronological order of events:	


Standard Operating Procedure: Cyber Incident Response

Date of incident, start time and duration	
Escalations done including approvals sought on interim measures to mitigate the event, and reasons for taking such measures	
Stakeholders informed or involved	
Channels of communications used (e.g. email, internet, sms, press release, website notice, etc.)	
Rationale on the decision/activation of BCP and/or DR	
5) Root Cause Analysis (RCA):	
Factors that caused the problem/ Reasons for occurrence, Cause and effects of incident	
Interim measures to mitigate/resolve the issue, and reasons for taking such measures, and	
Steps identified or to be taken to address the problem in the longer term. List the remedial measures/corrections affected (one time measure) and/or corrective actions taken to prevent future occurrences of similar types of incidents.	
6) Date/target date of resolution_____ (DD/MM/YYYY).	

Note: All fields are REQUIRED to be filled unless otherwise stated.



Standard Operating Procedure: Cyber Incident Response

B. Cert-in template for reporting Cyber Incident

Incident Reporting Form

I am: ☐ the effected entity ☐ reporting incident affecting other entity

Contact Information of the Reporter

Name & Role/Title ☐ Individual ☐ Organization

Organization name (if any)

Contact No.

Email:

Address:

Basic Incident Details

Affected entity.
(If not same as reporting entity above)

Incident Type

- | | | |
|--|---|---|
| ☐ Targeted scanning/probing of critical activities networks/systems. | ☐ Data Breach | ☐ Attacks or malicious/suspicious affecting system/servers/networks/ |
| ☐ Compromise of critical system/information Big Data, | ☐ Data leak | |
| ☐ Unauthorized access of IT system/data asset | ☐ Attack on Internet of Things (IoT) devices | software/ applications related to |
| ☐ Defacement or intrusion into website Robotics,3D | and associated system, networks, | Block chain, virtual assets, virtual |
| ☐ Malicious code attacks manufacturing, t | software, servers. | Exchange, custodian wallets, |
| | ☐ Attacks or incident affecting Digital | and 4D Printing, additive |
| | Payment system | Drones |
| ☐ Attack on servers such as Database, Mail and DNS suspicious activities and network devices such as Routers. | ☐ Attacks through Malicious mobile Apps | ☐ Attacks or malicious/ affecting system/ servers/software/ |
| | ☐ Fake mobile Apps | |
| ☐ Identify theft, spoofing and phishing attack. Intelligence | ☐ Unauthorized access to social media | applications related to Artificial |
| ☐ DoS / DDoS Attacks. | Accounts | and Machine Learning. |
| ☐ Attack on critical infrastructure, SCADA and operational technology systems and Wireless networks | ☐ Attacks or malicious / suspicious activities affecting Cloud computing | ☐ Other (Please Specify) |
| | system/server/software/applications. | |
| ☐ Attack on Application such as E-Governance, E- Commerce etc. | | |

Is the affected system/ network critical to the organization's mission? (Yes/No).
(Brief Details.)



Standard Operating Procedure: Cyber Incident Response

Basic Information of Affected System (Provide Information that is readily available.)	Domain/URL: IP Address: Operating System: Make/ Model/Cloud details: Affected Application details (if any): Location of affected system (Including City, Region & Country) Network and name of ISP:
Brief description of incident:	Occurrence date and time (dd/mm/yyyy hh:mm): Detection date & time (dd/mm/yyyy hh:mm):
Note: (A) The form provides general guidance in terms of information which could be relevant to the incident. (B) It is not mandatory to fill and /or sign this form. Incidents may also be reported by providing relevant information in the communication itself or in any other readable form. (C) Reporting entity may, if desired, also provide relevant information other than mentioned in this form	
Mail/Fax incident report to: CERT-in, Electronics Niketan, CGO Complex, New Delhi 110003 Fax:+91-11-24368546 or email at: incident@cert-in.org.in	

C. Incidents reported by end-users' priority in PSD tool may be re-categorized as per below table

Priority Level	Description	Response Time	Resolution Time
P1 Critical	- Data breach, ransomware, or major security compromise affecting all users or critical systems.	Within 1 hour	ASAP / Best Effort (typically within 8 hours)
P2 - High	Multiple users affected by the incident (> 5) or high-risk issues	Within 2 hours	Within 24 hours
P3 Medium	- Limited users affected (<5), moderate risk issues.	Within 4-24 hours	Within 48 hours
P4 - Low	Minor issues, informational alerts.	Within 48 hours	Within 96 hours

D. Cyber Crisis Criteria

Priority	Description
Crisis	1. When COMPANY is no longer able to manage key external factors 2. When senior leaders at COMPANY determine that mobilising a crisis response team is essential to protect the organization.



Standard Operating Procedure: Cyber Incident Response

3. When employee or customer data is compromised across several regions, resulting in mandatory public disclosure, widespread media attention, and the need for internal communication.

E. Types of Cyber Crisis

Impact Category	Description	Example
Disruption-Induced Financial Impact	The disruption of essential PFL services or applications can hinder operations and result in financial setbacks due to service downtime.	1. Malware infection across multiple endpoints (desktops, laptops, servers). 2. Denial-of-service (DDoS) or brute force attacks rendering key applications unusable.
Breach of Vendor Environment and Data Loss	Loss or compromise of sensitive data—whether due to cyberattacks, human error, or insider threats—may violate client agreements and contractual terms.	1. Organization-wide malware incident leading to unauthorized access and exfiltration of sensitive client data.
Loss of Intellectual Property (IP)	Unauthorized access or theft of proprietary information or trade secrets can result in significant financial damage and competitive disadvantage	1. Cyber intrusion leading to the
Compliance and Regulatory Exposure	Failing to meet legal, regulatory, or internal compliance obligations can result in penalties, financial liabilities, and operational restrictions.	1. Regulatory fine for non-compliance with GDPR following exposure of clients' personally identifiable information (PII).
Reputational Harm	Negative public perception due to security incidents or data breaches can damage ORG's brand image and reduce stakeholder trust and customer loyalty	1. Public disclosure of confidential client data. 2. Unauthorized activity on PFL's social media accounts, disseminating false information.
Direct Financial Threats	Cyber events may lead to direct monetary losses through fraud, extortion, or system unavailability	1. Major ransomware outbreak affecting core operations. 2. Financial fraud resulting from a business email compromise (BEC) incident
Threat to Human Life or Well-being	Certain incidents may have serious consequences on employees' safety, mental health, or morale, especially when personal data is exposed or misused.	1. Employee morale decline caused by leakage and exploitation of personal information.



Standard Operating Procedure: Cyber Incident Response

F. Contact Details of Regulators / Authorities

Mandatory reporting to the following regulators / authorities:

Name of Regulator	Address	Incident Reporting Method
Reserve Bank of India	Reserve Bank of India, Department of Supervision, 3rd Floor, World Trade Centre, Cuffe Parade, Colaba, Mumbai - 400 005.	RBI's DAKSH Portal https://daksh.rbi.org.in/
Cert-In	Cert-In, Electronics Niketan, CGO Complex, New Delhi 110003	Email : incident@cert-in.org.in Fax:+91-11-24368546
UIDAI	Unique Identification Authority of India, Bangla Sahib Road, Behind Kali Mandir, Gole Market, New Delhi - 110001	Email: help@uidai.gov.in Call : 1947 Or any acceptable method prescribed by UIDAI
CyMAC Control Room	Cyber Multi Agency Centre (CyMAC) Ministry of Home Affairs, GOI	Email: cycordadmin.mha@gov.in Landline: 011- 23094060

Incident Reporting to below regulators / authorities only if applicable:

I4C - National Cyber Crime Reporting Portal	Indian Cybercrime Coordination Centre, 5th Floor, NDCC-II Building, Jai Singh Road, New Delhi	https://cybercrime.gov.in/ or Call : 1930
SEBI	SEBI Bhavan, Plot C4-A, G Block, Bandra Kurla Complex, Mumbai - 400051	Email : mkt_incidents@sebi.gov.in
IRDAI	Insurance Regulatory Development Authority of India (IRDAI), Sy No. 115/1, Financial District, Nanakramguda, Gachibowli, Hyderabad - 500032	Email: infosec@irdai.gov.in
